

Incident Response Playbooks

Operational playbooks for phishing, ransomware, and insider-threat scenarios

Playbook Design Standard

- Each playbook follows Trigger -> Triage -> Evidence -> Containment -> Eradication -> Recovery -> Communication -> Closure.
- Decision points identify when to escalate severity, involve legal/privacy, isolate systems, disable accounts, or preserve forensic evidence.
- Evidence is collected before destructive actions when operationally safe and appropriate.

Phishing / Account Compromise

Trigger: User report, email-security alert, impossible/risky sign-in, suspicious forwarding rule, or credential-use anomaly.

Triage & Evidence

- Preserve message headers and body.
- Identify sender, recipient, URL/attachment, delivery scope, clicks, and credential submission.
- Review sign-ins, MFA events, mailbox rules, OAuth grants, and endpoint alerts.

Containment

- Block sender/domain/URL/hash as supported.
- Reset or revoke credentials/tokens if compromise is suspected.
- Disable account when active misuse is confirmed.
- Remove malicious messages from other mailboxes where supported.

Eradication

- Remove malicious inbox/forwarding rules.
- Revoke unauthorized OAuth grants.
- Remediate affected endpoint if payload execution occurred.

Recovery

- Restore account with strong MFA.
- Verify legitimate mailbox settings and user access.
- Monitor for recurrence and related accounts.

Escalation: Escalate when privileged accounts, sensitive data, widespread delivery, successful payload execution, or confirmed account misuse are involved.

Ransomware

Trigger: EDR ransomware behavior, mass file modification, ransom note, encryption extensions, lateral movement, or user report.

Triage & Evidence

- Isolate affected hosts immediately where safe.
- Identify impacted systems, user accounts, shares, encryption scope, and initial access clues.
- Preserve EDR telemetry, logs, ransom note, file samples/hashes, and network evidence.

Containment

- Network-isolate impacted endpoints/servers.
- Disable compromised credentials and remote access paths.
- Block identified malicious indicators.
- Protect backup infrastructure from affected credentials or network segments.

Eradication

- Remove persistence and malicious tooling.
- Patch exploited vulnerabilities.
- Rebuild compromised systems when integrity cannot be trusted.

Recovery

- Restore from known-good backups.
- Validate systems before reconnecting.
- Monitor for re-encryption, persistence, and lateral movement.

Escalation: Escalate immediately for business-critical impact, widespread encryption, backup compromise, data-exfiltration evidence, or regulated-data exposure.

Insider Threat / Unauthorized Data Access

Trigger: DLP alert, unusual downloads, excessive database queries, removable-media activity, abnormal cloud sharing, or manager/security report.

Triage & Evidence

- Preserve logs before confronting the user.
- Confirm identity, role, business need, data sensitivity, volume, destination, and timing.
- Coordinate carefully with HR/legal according to organizational policy.

Containment

- Restrict access based on verified risk and authorization.
- Disable external sharing or revoke tokens as appropriate.
- Preserve endpoint/cloud evidence and avoid unnecessary evidence alteration.

Eradication

- Remove unauthorized permissions, tokens, scripts, or sharing links.
- Address process/control gaps that enabled excessive access.

Recovery

- Restore only approved access.
- Monitor high-risk actions and complete access recertification.

Escalation: Escalate when intentional misuse is suspected, restricted data is involved, evidence may be destroyed, or legal/HR action is required.

Closure Checklist

- Timeline complete and major decisions documented.
- Indicators and affected assets/accounts recorded.
- Containment and eradication actions validated.
- Business owner confirms service recovery where applicable.
- Root cause and contributing factors documented at the appropriate confidence level.
- Corrective actions have owners and target dates.
- Lessons learned are fed back into controls, detection, training, and playbooks.